AEGIS BANK

Data Classification Policy

Enterprise AI Decision & Knowledge Platform for Modern Banking

---

Document Information

Field	Details
Document Title	Data Classification Policy
Document ID	**AB-SEC-005**
Department	Information Security
Version	v1.2
Last Updated	July 24, 2026
Document Owner	Information Security Department
Classification	Confidential
Review Date	July 24, 2027
Approved By	**Sami Khan – Chief Executive Officer (CEO)**

Confidentiality Notice

This Data Classification Policy defines the standards used by Aegis Bank to categorize, protect, handle, store, and share information assets according to their sensitivity and business impact.

This policy applies to all employees, contractors, third parties, and systems processing Aegis Bank information.

Unauthorized access, disclosure, or misuse of classified information is prohibited.

Table of Contents

1. Purpose

2. Scope
3. Policy Statement
4. Data Classification Principles
5. Classification Levels
6. Public Information
7. Internal Information
8. Confidential Information
9. Restricted Information
10. Data Handling Requirements
11. Data Access Controls
12. Data Storage & Transmission
13. Data Disposal Requirements
14. Employee Responsibilities
15. Practical Examples
16. FAQs
17. Revision History
18. Document Approval

---

1. Purpose

The purpose of this policy is to establish a consistent framework for identifying and protecting Aegis Bank information assets.

This policy ensures:

- Sensitive information receives appropriate protection.
- Access is granted based on business requirements.
- Customer data is protected.
- Regulatory obligations are satisfied.

- Security risks are reduced.

---

2. Scope

This policy applies to all information created, processed, stored, or managed by Aegis Bank.

Covered information includes:

- Customer information.
- Financial records.
- Employee information.
- Banking policies.
- Security documentation.
- Application data.
- Database records.
- Business documents.
- AI system data.
- Third-party information.

---

3. Policy Statement

All Aegis Bank information must be classified according to its sensitivity level before being stored, processed, or shared.

Information owners are responsible for ensuring appropriate classification and protection controls.

Data classification levels are:

1. Public
2. Internal
3. Confidential
4. Restricted

---

4. Data Classification Principles

Aegis Bank follows these principles:

Need-to-Know Access

Employees receive access only to information required for their responsibilities.

Least Privilege

Users receive the minimum level of access necessary.

Data Protection Throughout Lifecycle

Information must remain protected during:

- Creation.
- Storage.
- Usage.
- Sharing.
- Archiving.
- Disposal.

Risk-Based Protection

Higher sensitivity data requires stronger security controls.

---

5. Classification Levels Overview

Classification	Sensitivity Level	Examples
Public	Low	Marketing material, public announcements
Internal	Moderate	Internal procedures, employee guidelines
Confidential	High	Financial records, business strategies

Classification	Sensitivity Level	Examples
Restricted	Very High	Customer credentials, security keys

---

6. Public Information

Public information is data approved for external sharing.

Examples:

- Website content.
- Public reports.
- Marketing materials.
- Press releases.
- Product brochures.

Handling Requirements

Public information:

- May be shared externally.
- Must be approved before publication.
- Must not contain sensitive information.

---

7. Internal Information

Internal information is intended only for Aegis Bank employees and approved personnel.

Examples:

- Internal procedures.
- Employee guidelines.
- Operational manuals.
- Department communications.
- Training materials.

Handling Requirements

Internal data:

- Must not be shared publicly.
- Requires employee authentication.
- Should be stored in approved systems.

---

8. Confidential Information

Confidential information could cause business or customer impact if disclosed.

Examples:

- Customer account information.
- Loan applications.
- Financial reports.
- Employee records.
- Business strategies.
- Vendor agreements.

Handling Requirements

Confidential information requires:

- Access control.
- Encryption where applicable.
- Secure storage.
- Authorized sharing only.
- Audit logging.

---

9. Restricted Information

Restricted information represents the highest sensitivity level.

Unauthorized disclosure could create severe financial, legal, operational, or security impact.

Examples:

- Customer authentication data.
- Encryption keys.
- Security configurations.
- Incident investigation records.
- Production database credentials.
- Vulnerability reports.
- Privileged administrator information.

Handling Requirements

Restricted data requires:

- Strict access approval.
- Multi-Factor Authentication.
- Encryption.
- Detailed audit logging.
- Limited distribution.
- Security monitoring.

---

10. Data Handling Requirements

Employees must follow classification-specific handling rules.

Activity	Public	Internal	Confidential	Restricted
External Sharing	Allowed	Not Allowed	Approval Required	Prohibited
Encryption	Recommended	Recommended	Required	Mandatory
Access Approval	No	Manager Approval	Owner Approval	Security Approval
Audit Logging	Optional	Recommended	Required	Mandatory

---

11. Data Access Controls

Access decisions must consider:

- Employee role.
- Business requirement.
- Data sensitivity.
- Regulatory requirements.
- Security risk.

Access reviews shall be performed periodically to ensure:

- Appropriate permissions.
- Removal of unnecessary access.
- Compliance with least privilege principles.

---

12. Data Storage & Transmission

Sensitive information must only be stored in approved systems.

Requirements include:

- Encryption during transmission.
- Secure storage locations.
- Access monitoring.
- Backup protection.
- Secure file sharing methods.

Employees must not store confidential or restricted information on:

- Personal devices.
- Unauthorized cloud storage.
- External drives without approval.

---

13. Data Disposal Requirements

Information must be securely destroyed when no longer required.

Approved disposal methods include:

- Secure file deletion.
- Media destruction.
- Certified data wiping.
- Document shredding.

Restricted information must never be disposed of using normal deletion methods.

---

14. Employee Responsibilities

Employees must:

- Understand data classifications.
- Protect information according to classification level.
- Report accidental disclosure.
- Use approved storage systems.
- Follow access control requirements.

Employees must not:

- Share confidential information without authorization.
- Bypass security controls.
- Copy restricted data unnecessarily.
- Send sensitive data through unsecured channels.

---

15. Practical Examples

Example 1 – Customer Account Statement

A customer account statement contains:

- Account number.
- Transaction history.
- Personal information.

Classification

➡ Confidential

Required Protection

Encryption and authorized access only.

Example 2 – Production Database Credentials

Database administrator credentials provide access to banking systems.

Classification

➡ Restricted

Required Protection

MFA, privileged access management, and security monitoring.

Example 3 – Public Marketing Brochure

A product brochure published on the Bank website.

Classification

➡ Public

Required Protection

Approval before external publication.

Example 4 – Internal Employee Procedure

An internal workflow document used by employees.

Classification

➡ Internal

Required Protection

Available only to authorized employees.

---

16. Data Owner Responsibilities

Every classified information asset must have an assigned Data Owner responsible for ensuring appropriate protection.

Data Owners are responsible for:

- Assigning correct classification levels.
- Reviewing access permissions.
- Approving data sharing requests.
- Ensuring security controls are applied.
- Reviewing classification periodically.
- Reporting security concerns.

Examples of Data Owners:

Data Type	Responsible Owner
Customer Data	Customer Operations Department
Employee Records	Human Resources Department
Financial Reports	Finance Department
Security Logs	Information Security Department
Application Data	Technology Department

---

17. Data Custodian Responsibilities

Data Custodians are responsible for the technical management and protection of information.

Responsibilities include:

- Implementing security controls.
- Maintaining storage systems.
- Managing backups.

- Applying encryption.
- Monitoring access activity.
- Supporting audits.

Examples of Data Custodians:

- Database Administrators.
- Cloud Infrastructure Teams.
- System Administrators.
- Application Support Teams.

---

18. Third-Party Data Sharing Requirements

Aegis Bank may share information with approved third parties only when there is a legitimate business requirement.

Before sharing data:

- Vendor security assessment must be completed.
- Appropriate agreements must be signed.
- Data classification must be reviewed.
- Access must be limited.
- Security requirements must be defined.

Third parties must:

- Protect Aegis Bank information.
- Follow contractual security requirements.
- Report security incidents.
- Delete information when no longer required.

---

19. AI System Data Classification Requirements

Aegis Bank AI systems, including **Aegis AI OS**, must follow strict data classification requirements.

AI systems must:

- Process information according to classification level.
- Prevent unauthorized data exposure.
- Maintain access control.
- Log AI data interactions.
- Protect confidential banking documents.

AI Data Handling Rules

Data Classification	AI Usage Requirement
Public	Allowed for approved AI use cases
Internal	Allowed with employee authentication
Confidential	Requires controlled AI environment
Restricted	Requires explicit security approval

Examples

Example 1 – Internal Policy Document

Employee Handbook uploaded into Aegis AI OS.

Classification:

➡️ Internal

Allowed:

Employees can query approved HR information.

Example 2 – Customer Financial Records

Customer transaction history uploaded into AI system.

Classification:

➡️ Confidential

Requirement:

Restricted access, encryption, and audit logging.

Example 3 – Database Credentials

Production database administrator passwords.

Classification:

➡️ Restricted

Requirement:

Not allowed in general AI systems.

---

20. Data Breach Handling

Any unauthorized access, disclosure, modification, or loss of classified information must be treated as a security incident.

Examples:

- Sending confidential documents to the wrong recipient.
- Unauthorized database access.
- Lost device containing sensitive information.
- Accidental public exposure of files.

Response Process

When a data breach occurs:

Step 1 — Report

Employee immediately informs:

- Information Security Team.
- Manager.

- Relevant department owner.

Step 2 — Assessment

Security Team determines:

- Data classification level.
- Impact scope.
- Affected systems.
- Regulatory obligations.

Step 3 — Containment

Actions may include:

- Removing unauthorized access.
- Blocking accounts.
- Recovering exposed information.
- Securing affected systems.

Step 4 — Recovery

The Bank restores secure operations and implements preventive measures.

---

21. Classification Review Process

Information classifications must be reviewed periodically.

Reviews should occur:

- Annually.
- During major system changes.
- After security incidents.
- When business requirements change.

During review, Data Owners verify:

- Current classification accuracy.
- Access permissions.
- Protection controls.
- Retention requirements.

---

22. Data Classification Violations

Examples of violations include:

- Sharing confidential data without approval.
- Storing restricted data in unauthorized locations.
- Removing security labels.
- Sending sensitive files through personal email.
- Accessing data without business justification.

Violations may result in:

- Access removal.
- Employee disciplinary action.
- Security investigation.
- Legal or regulatory action where applicable.

---

23. Practical Banking Scenarios

Scenario 1 – Loan Application Data

A Credit Officer receives a customer's loan application containing:

- Income details.
- Identification documents.
- Financial history.

Classification:

➡️ Confidential

Required Controls:

- Authorized access only.
- Secure document storage.
- Encryption during transmission.

Scenario 2 – Security Investigation Report

SOC creates a report after investigating a cyber attack.

Classification:

➡️ Restricted

Required Controls:

- Security team access only.
- MFA protection.
- Detailed audit logging.

Scenario 3 – New Product Announcement

Marketing prepares information about a new banking product before public release.

Classification:

➡️ Internal

Required Controls:

- Employee access only until publication approval.

Scenario 4 – Customer Password Data

Authentication secrets stored by banking systems.

Classification:

➡️ Restricted

Required Controls:

- Encryption.
- Strong access controls.
- No direct employee access.

---

24. Frequently Asked Questions (FAQs)

Q1. Who decides the classification level of information?

The Data Owner is responsible for assigning and reviewing the classification level.

Q2. Can Confidential information be shared externally?

Only with proper authorization, approved business purpose, and required security controls.

Q3. What is the highest data classification level?

Restricted is the highest classification level at Aegis Bank.

Q4. Can employees store customer information on personal devices?

No. Confidential and Restricted information must only be stored in approved Bank systems.

Q5. How should employees handle accidental data exposure?

Immediately report the incident to the Information Security Team according to the Incident Response Plan.

Q6. Can AI systems process confidential banking documents?

Yes, but only through approved AI environments with proper access controls, monitoring, and security protections.

---

25. Related Documents

This policy should be read together with:

- Password Policy (AB-SEC-001)
- Multi-Factor Authentication Policy (AB-SEC-002)
- Cyber Security Policy (AB-SEC-003)
- Incident Response Plan (AB-SEC-004)
- AI Security Policy (AB-AI-003)
- Data Retention Policy (AB-COMP-005)
- Customer Privacy Policy (AB-COMP-002)

---

26. Revision History

Version	Date	Description	Author
v1.0	February 01, 2026	Initial Release	Information Security Department
v1.1	May 10, 2026	Added AI Data Classification Requirements	Information Security Department
v1.2	**July 24, 2026**	**Enhanced Data Handling Controls, Third-Party Sharing Requirements, and AI Security Guidelines**	**Information Security Department**

---

27. Document Approval

Field	Details
Document ID	**AB-SEC-005**
Document Title	**Data Classification Policy**
Department	Information Security

Field	Details
Version	**v1.2**
Classification	**Confidential**
Document Owner	Information Security Department
Approved By	**Sami Khan – Chief Executive Officer (CEO)**
Approval Date	**July 24, 2026**
Next Review Date	**July 24, 2027**

Document Control

Attribute	Value
Document Status	Approved
Distribution	Information Security, IT Operations, Compliance, Risk Management, All Employees
Language	English
Storage Location	Aegis Bank Document Management System (DMS)
Retention Period	7 Years
Supersedes	Data Classification Policy v1.1

End of Document

Aegis Bank
Enterprise AI Decision & Knowledge Platform for Modern Banking

© 2026 Aegis Bank. All Rights Reserved.